

OBSIDIAN RIDGE CYBER ASSURANCE LLP

Application Security | VAPT | Governance Evidence

Web Application

Vulnerability Assessment & Penetration Testing Report

FleetOps Partner Portal

Prepared for HeliosFleet Logistics Pvt. Ltd.

OVERALL RISK	FINDINGS	CRITICAL	HIGH
HIGH	08	01	03

Report ID	ORCA-HF-FOP-WA-2026-05-R1
Assessment Window	18 May 2026 - 30 May 2026
Report Date	05 June 2026
Classification	Confidential - Client Restricted

This report contains security-sensitive technical information and should be handled according to the client data classification policy.

DOCUMENT CONTROL & DISTRIBUTION

Report Identification

Client	HeliosFleet Logistics Pvt. Ltd.
Application	FleetOps Partner Portal - Web Application and REST APIs
Assessment Type	Web Application Vulnerability Assessment and Penetration Testing
Environment	UAT/Staging environment hosted on client-managed cloud tenancy
Assessment Window	18 May 2026 - 30 May 2026
Report Date	05 June 2026
Prepared By	Obsidian Ridge Cyber Assurance LLP
Classification	Confidential - Client Restricted

Document Version History

Version	Date	Prepared / Reviewed By	Change Summary
0.1	31 May 2026	Nikhil Rao / Sana Mirza	Initial technical draft prepared after validation
0.9	03 June 2026	Rhea Menon	Quality review, risk normalization, and evidence verification
1.0	05 June 2026	Ananya Sethi	Client-ready release version

Distribution List

Name	Role	Organization	Purpose
Maya Krishnan	CISO	HeliosFleet Logistics Pvt. Ltd.	Executive sponsor and risk owner
Arvind Narang	Head of Engineering	HeliosFleet Logistics Pvt. Ltd.	Application remediation owner
Karan Bhatia	Product Manager - FleetOps	HeliosFleet Logistics Pvt. Ltd.	Product workflow owner
Rhea Menon	Engagement Manager	Obsidian Ridge Cyber Assurance LLP	Assessment delivery owner

Handling Note

This report contains security-sensitive evidence including endpoint names, parameter names, role details, and vulnerability proof material. Distribution should be limited to authorized stakeholders and remediation teams.

EXECUTIVE SUMMARY

Executive Summary

Obsidian Ridge Cyber Assurance LLP performed a vulnerability assessment and penetration test of the FleetOps Partner Portal operated by HeliosFleet Logistics Pvt. Ltd. The application supports partner onboarding, shipment tracking, invoice review, claim attachments, delivery exception handling, and workflow approvals. The assessment identified authorization, authentication, browser security, and content handling weaknesses that should be remediated before the next production release.

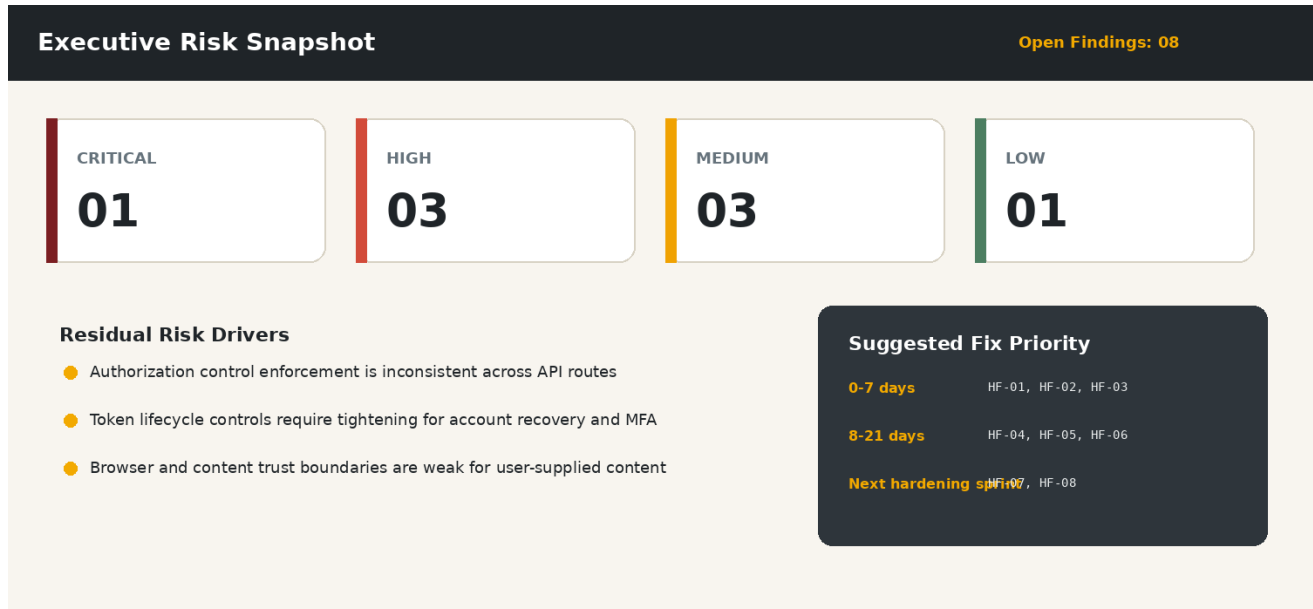


Figure 1: Executive risk snapshot for open findings

OVERALL RISK	CRITICAL	HIGH	MEDIUM
HIGH	01	03	03

The assessment team assessed the overall risk as HIGH. The primary risk theme is inconsistent authorization enforcement between UI-level controls and API-level services. The most significant findings were broken object-level authorization in invoice retrieval and privilege escalation through client-controlled role context. These issues can expose sensitive commercial data and bypass workflow approvals.

Management View of Findings

Severity	Count	Primary Risk Area	Recommended SLA
Critical	1	Cross-tenant invoice access through API object authorization gap	0-7 calendar days
High	3	Workflow privilege escalation, stored XSS, reset token reuse	8-14 calendar days
Medium	3	CORS, file upload isolation, MFA throttling	15-30 calendar days
Low	1	Browser hardening header gaps on legacy pages	Next hardening sprint

Key Business Risks

- Cross-tenant data exposure: partner users may retrieve invoice and consignee data outside their authorized tenant boundary.
- Workflow integrity gap: shipment release approvals can be manipulated by changing client-supplied role information.
- Client-side trust weakness: stored content, browser headers, and CORS controls require hardening to reduce session-context abuse.
- Identity lifecycle gap: account recovery and MFA controls require single-use and rate-limiting enforcement to maintain authentication assurance.

01

Engagement Context

Business scope, assumptions, credential coverage, sampling basis, exclusions, team, and audit timeline.

HeliosFleet Logistics Pvt. Ltd. | FleetOps Partner Portal

INTRODUCTION, OBJECTIVE, SCOPE & CONSTRAINTS

1. Introduction

HeliosFleet Logistics Pvt. Ltd. engaged Obsidian Ridge Cyber Assurance LLP to assess the security posture of the FleetOps Partner Portal. The portal enables third-party logistics partners to view shipments, raise claims, upload proof-of-delivery files, review invoices, and participate in dispatch release workflows.

2. Objective

- Identify exploitable vulnerabilities in the web application, supporting REST APIs, session flows, and partner-facing workflows.
- Validate whether authorization, authentication, input handling, file upload, and browser security controls are implemented consistently.
- Provide prioritized, evidence-based observations with remediation guidance and retest criteria for engineering teams.
- Map findings to recognized web application security standards and provide a practical remediation roadmap.

3. Limitations and Assumptions

- Testing was performed against the UAT/staging environment using credentials and test data supplied by HeliosFleet.
- No denial-of-service, destructive data modification, live payment authorization, or persistence beyond agreed test accounts was performed.
- The application state, deployed code, and cloud gateway rules are assumed to match the UAT deployment available during the assessment window.
- Third-party identity provider internals, managed cloud control plane, and vendor-hosted notification services were treated as trusted external dependencies unless behavior was observable through the application.

4. Engagement Scope

Scope Area	In-Scope Item	Coverage Performed
Web Frontend	partner.heliosfleet.internal UI routes	Authenticated workflow, authorization, DOM/client-side controls, dashboard widgets
REST APIs	/api/v2/* application APIs	Authentication, authorization, business logic, input validation, CORS, error handling
Identity Flows	Login, MFA, password reset, session management	Token lifecycle, MFA verification behavior, session invalidation checks
File Handling	Claims proof attachment upload and preview	MIME handling, storage origin, executable content handling
Roles	partner_ops, partner_finance, ops_reviewer, read_only_auditor	Horizontal and vertical access checks across workflows

5. Testing Credentials

Account	Assigned Role	Tenant / Context	Credential Handling
partner_acme_ops	partner_ops	ACME-LOGISTICS	Password issued through encrypted channel; rotated after testing
partner_acme_fin	partner_finance	ACME-LOGISTICS	Used for invoice workflow and role comparison
rivergate_view	partner_ops	RIVERGATE_COLDCHAIN	Used only for object ownership validation baseline
ops_review_uat	ops_reviewer	Internal operations queue	Used for delivery exception review and XSS rendering validation
audit_readonly	read_only_auditor	Global read-only test context	Used for discovery and non-invasive validation

Passwords, MFA seeds, reset tokens, and session identifiers are intentionally redacted from this report. Token fragments shown in evidence screenshots are shortened and non-reusable.

6. Exclusions, Additions, and Deviations

Type	Item	Rationale / Notes
Exclusion	DDoS, stress testing, resource exhaustion	Out of scope to avoid availability impact on shared UAT services
Exclusion	Phishing, social engineering, physical security	Not part of application VAPT engagement
Exclusion	Cloud account takeover and managed IDP internals	Covered only through observable application behavior
Addition	Credentialed business-logic testing	Added after kickoff due to multi-tenant partner workflows
Deviation	MFA OTP attempt volume capped	Manual cap applied to avoid lockout side effects and excessive traffic

7. Sampling Criteria

- High-value workflows handling invoice, consignee, shipment, claim, or release approval data were prioritized.
- Endpoints were sampled across tenant boundaries, role boundaries, state transitions, and direct API invocation paths.
- Inputs accepting stored text, file content, cross-origin access, tokens, or identifiers were selected for deeper validation.
- Legacy report pages were included where headers, iframe behavior, or rendering differed from the modern React shell.

8. Details of Auditing Team

Name	Role	Responsibilities
Rhea Menon	Engagement Manager	Kickoff, client coordination, quality review, risk normalization
Nikhil Rao	Lead Application Security Consultant	Threat modeling, access control testing, API testing, report authoring
Sana Mirza	Security Consultant	Input validation, authentication flows, file upload, browser security checks
Kunal Shah	Technical QA Reviewer	Evidence review, reproducibility checks, CVSS consistency

02

Security Assessment Methodology

Standards, approach, testing environment, assessment type, tools, and criteria used for evidence-based validation.

HeliosFleet Logistics Pvt. Ltd. | FleetOps Partner Portal

METHODOLOGY, APPROACH, ENVIRONMENT & TOOLS

9. Audit Activities and Timelines

Date / Period	Activity	Output
18 May 2026	Kickoff, scope confirmation, access validation	Rules of engagement and credential matrix confirmed
19-20 May 2026	Application mapping and authenticated crawling	Endpoint inventory, role mapping, workflow notes
21-24 May 2026	Manual API and authorization testing	Object ownership, role transition, workflow checks
25-27 May 2026	Input validation, file upload, browser security testing	XSS, CORS, headers, attachment handling evidence
28 May 2026	Authentication and session testing	Reset token, MFA throttling, session lifecycle observations
29-30 May 2026	Validation, triage, risk scoring	Reproducible findings and severity normalization
31 May-05 June 2026	Reporting and QA review	Client-ready report and remediation roadmap

10. Audit Methodology and Criteria / Standards Referred

The assessment followed a hybrid methodology combining automated discovery with manual exploitation-focused validation. Automated tools were used for coverage and signal collection; final findings were included only after manual validation and impact analysis.

Reference	Use in Assessment
OWASP Top 10:2025	Risk categorization and executive communication of common web application risks
OWASP Web Security Testing Guide	Manual test case planning across authentication, authorization, input validation, configuration, and business logic
OWASP ASVS 5.0.0	Control verification reference for access control, authentication, file handling, and browser security
CVSS v3.1	Technical severity scoring and vector notation
Client Rules of Engagement	Constraints, allowed accounts, test windows, exclusions, and evidence-handling requirements

11. Approach and Methodology

Phase	Activities	Evidence Generated
Discovery	Authenticated crawl, endpoint inventory, role enumeration, request replay setup	Application map and endpoint list
Threat Modeling	Identification of assets, trust boundaries, tenant boundaries, and approval states	Abuse cases and test hypotheses
Manual Validation	API tampering, authorization bypass, workflow manipulation, token lifecycle testing	HTTP requests/responses and screenshots
Configuration Review	CORS, headers, file handling, error behavior, session cookie attributes	Header captures and browser evidence
Risk Analysis	Exploitability, affected data, business impact, likelihood, compensating controls	CVSS scores and remediation priority
Reporting	QA review, duplicate removal, retest criteria definition	Final report with evidence and recommendations

12. Type of Assessment and Testing Environment

Assessment Type	Credentialed web application VAPT with manual penetration testing focus
Testing Model	Grey-box: role credentials and high-level architecture notes were

	supplied; source code was not reviewed
Environment	UAT/staging web and API deployment behind client-managed gateway
Data Handling	Only assigned test data and pre-approved samples were used. Sensitive values in evidence are redacted.
Network Origin	Assessment performed from approved consultant IP ranges over VPN

13. Tools and Software Used

Tool / Software	Purpose	Notes
Burp Suite Professional	Proxying, request replay, manual API testing	Used for interception, evidence capture, and non-destructive validation
OWASP ZAP	Authenticated crawl and passive checks	Used as secondary coverage tool
Postman / cURL	API request construction and repeatability	Used for controlled proof capture
Browser DevTools	DOM review, console proof, header validation	Chrome and Firefox used for client-side behavior review
Nmap	Port and service confirmation for in-scope hosts	No invasive service exploitation performed
jwt.io offline decoder / local scripts	Token claim review	No secret brute force or production key attacks performed
Custom checklists	Manual test case tracking	Derived from OWASP WSTG and ASVS controls

14. Findings Summary

ID	Severity	Finding	Affected Component	Priority
HF-01	Critical	Broken Object-Level Authorization in Invoice Retrieval API	/api/v2/shipments/{shipmentId}/invoice and Partner Invoice screen	P0 - fix before production release
HF-02	High	Privilege Escalation via Client-Controlled Role Context	/api/v2/release-notes/{noteId}/approve and Dispatch Release workflow	P0 - immediate server-side authorization fix
HF-03	High	Stored Cross-Site Scripting in Delivery Exception Notes	Delivery Exceptions > Note field and Operations Dashboard widget	P1 - fix within current sprint
HF-04	High	Password Reset Token Reuse After Successful Account Recovery	/account/reset/confirm and Identity Recovery service	P1 - invalidate token lifecycle defect
HF-05	Medium	CORS Policy Reflects Untrusted Origins with Credential Support	API Gateway CORS middleware for /api/v2/*	P2 - gateway configuration hardening
HF-06	Medium	Unrestricted SVG Upload Stored Under Trusted Application Origin	Claims > Proof Attachment upload and /uploads/claims/* content host	P2 - content validation and storage isolation
HF-07	Medium	No Effective Rate Limiting on MFA OTP Verification Endpoint	/api/v2/auth/mfa/verify	P2 - rate limit and lockout controls
HF-08	Low	Incomplete Browser Security Headers on Authenticated Pages	Partner dashboard, invoice preview, and legacy report pages	P3 - hardening backlog with regression tests

15. Remediation Roadmap

Priority Window	Finding IDs	Recommended Action
0-7 days	HF-01, HF-02	Fix server-side authorization enforcement for object ownership and workflow role evaluation. Add negative access tests immediately.
8-14 days	HF-03, HF-04	Patch stored XSS rendering and enforce single-use reset tokens with session rotation.
15-30 days	HF-05, HF-06, HF-07	Harden gateway CORS, isolate or transform uploads, and add MFA route rate limiting.
Next hardening sprint	HF-08	Apply centralized browser security header baseline and regression checks.

Remediation Dependencies

- Authorization fixes should be implemented before retesting client-side workflow constraints.
- CORS, security headers, and upload isolation should be validated through gateway-level regression checks.
- Identity fixes should include audit log updates so security monitoring can confirm failed reset and MFA attempts.

Detailed Technical Observations

Validated vulnerabilities, affected assets, proof of concept evidence, business impact, root cause, and remediation criteria.



DETAILED OBSERVATION 01 - HF-01**HF-01 - Broken Object-Level Authorization in Invoice Retrieval API****CRITICAL**

CVSS v3.1

9.1 | CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:N

Mapped Standard

A01:2025 - Broken Access Control | WSTG-ATHZ-04 | ASVS 5.0.0 V4 Access Control

Affected Component

/api/v2/shipments/{shipmentId}/invoice and Partner Invoice screen

Status / Owner

Open / Platform API Team

Priority

P0 - fix before production release

Observation and Business Impact

The invoice retrieval endpoint enforces authentication but does not verify that the requested shipment belongs to the authenticated partner tenant. A partner-level account was able to enumerate another partner shipment ID and retrieve invoice metadata, consignee details, billable weight, tax components, and payment status.

An authenticated low-privileged partner could access commercial and personal information belonging to other customers. The finding impacts confidentiality and integrity because invoice references can be used to initiate disputes or reconcile unauthorized financial information.

Proof of Concept Evidence

Evidence Capture - HF-01

CRITICAL

Broken Object-Level Authorization in Invoice Retrieval API

Authenticated partner request

```
01 GET /api/v2/shipments/HFL-78291/invoice HTTP/2
02 Host: partner.heliosfleet.internal
03 Authorization: Bearer eyJ...partner_acme_ops
04 X-Tenant-Id: ACME-LOGISTICS
05 Accept: application/json
06
07 # Baseline owned shipment: HFL-78144 -> 200 OK
08 # Modified shipmentId to HFL-78291 from audit sample
```

API response containing another partner invoice

```
01 HTTP/2 200 OK
02 content-type: application/json
03 cache-control: no-store
04
05 {
06   "shipmentId": "HFL-78291",
07   "partnerCode": "RIVERGATE_COLDCHAIN",
08   "invoiceNo": "INV-FOP-2026-0518-8841",
09   "consignee": "M. Srinivasan, Pune",
10   "amountDue": "INR 82,450.00",
11   "paymentStatus": "Pending"
12 }
```

PoC interpretation

The authenticated ACME partner session successfully retrieved invoice data for RIVERGATE_COLDCHAIN by changing only the shipmentId path value. No tenant ownership error was returned.

Figure 2: Evidence capture for HF-01 - Broken Object-Level Authorization in Invoice Retrieval API

Controlled Validation Summary

1. Authenticated as partner_acme_ops and confirmed normal invoice access for an owned shipment.
2. Changed only the shipmentId path value to an identifier belonging to the Rivergate tenant sample.
3. Received HTTP 200 with invoice details instead of 403/404 authorization denial.
4. Repeated the check with two non-owned sample identifiers to validate that the behavior was not a caching anomaly.

Root Cause

Authorization checks are implemented at the UI query layer but not consistently enforced in the API service. The API trusts the path parameter and verifies only the session token, not the tenant-to-object relationship.

Recommended Remediation

Enforce server-side object ownership checks for every shipment and invoice query. Resolve the authenticated tenant ID from the server-side session or JWT claims, bind it to repository queries, and return a generic 404 for objects outside the tenant boundary. Add negative authorization tests for cross-tenant access in CI.

Retest Criteria

Using `partner_acme_ops`, access to HFL-78291 and other non-owned shipment IDs must return 404/403 and no invoice body. Server logs should show authorization denial without exposing the target object identifier.

DETAILED OBSERVATION 02 - HF-02

HF-02 - Privilege Escalation via Client-Controlled Role Context

HIGH

CVSS v3.1	8.1 CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N
Mapped Standard	A01:2025 - Broken Access Control WSTG-ATHZ-03 ASVS 5.0.0 V4
Affected Component	/api/v2/release-notes/{noteId}/approve and Dispatch Release workflow
Status / Owner	Open / Workflow Services Team
Priority	P0 - immediate server-side authorization fix

Observation and Business Impact

The dispatch release workflow accepts a roleContext value supplied by the client. A partner operations user could modify this value to finance_approver and approve a held release note without being assigned the finance approver role.

Unauthorized release approval can bypass segregation of duties, release shipments that require finance validation, and create audit trail inconsistencies because the transaction is recorded as an approved release.

Proof of Concept Evidence

Evidence Capture - HF-02

HIGH

Privilege Escalation via Client-Controlled Role Context

Partner operations approval request

```
01 POST /api/v2/release-notes/RN-45618/approve HTTP/2
02 Host: partner.heliosfleet.internal
03 Authorization: Bearer eyJ...partner_ops
04 Content-Type: application/json
05
06 {
07   "decision": "approve",
08   "roleContext": "finance_approver",
09   "comment": "Release validated during audit"
10 }
```

Workflow service response

```
01 HTTP/2 200 OK
02 content-type: application/json
03
04 {
05   "noteId": "RN-45618",
06   "previousState": "FINANCE_HOLD",
07   "newState": "RELEASE_APPROVED",
08   "approvedBy": "partner_acme_ops",
09   "effectiveRole": "finance_approver",
10   "auditRef": "wf-20260522-1304"
11 }
```

PoC interpretation

Changing a request field caused the workflow engine to treat a partner operations user as a finance approver. This demonstrates server-side trust in client-controlled role context.

Figure 3: Evidence capture for HF-02 - Privilege Escalation via Client-Controlled Role Context

Controlled Validation Summary

1. Opened a release note in FINANCE_HOLD state using a partner operations account.
2. Intercepted the approval request and changed the roleContext field from partner_ops to finance_approver.
3. Observed RELEASE_APPROVED in the API response and audit reference generated for the low-privileged user.
4. Confirmed that the same user had no finance approval role in the user profile API response.

Root Cause

The backend approval handler uses the roleContext request field for workflow authorization instead of resolving effective permissions from the identity provider and internal RBAC service.

Recommended Remediation

Remove all authorization decisions based on client-supplied role or permission fields. Use a centralized policy enforcement point backed by server-side claims and workflow state. Record both attempted and successful approval actions with immutable actor and role information.

Retest Criteria

Submitting finance_approver or admin values from partner_ops must fail with 403 and must not update release status. The API should ignore or reject roleContext entirely unless generated server-side.

DETAILED OBSERVATION 03 - HF-03**HF-03 - Stored Cross-Site Scripting in Delivery Exception Notes****HIGH**

CVSS v3.1

8.0 | CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:C/C:H/I:L/A:N

Mapped Standard

A03:2025 - Injection | WSTG-INPV-02 | ASVS 5.0.0 V5 Input Validation

Affected Component

Delivery Exceptions > Note field and Operations Dashboard widget

Status / Owner

Open / Front-End Experience Team

Priority

P1 - fix within current sprint

Observation and Business Impact

User-supplied delivery exception notes are stored by the API and later rendered in the operations dashboard without context-aware output encoding. A benign proof marker was executed in the browser context of an operations reviewer.

An attacker with partner credentials could execute JavaScript in the browser of operations or finance users, potentially performing same-origin actions, changing shipment data, or accessing session-scoped data exposed to the page.

Proof of Concept Evidence

Figure 4: Evidence capture for HF-03 - Stored Cross-Site Scripting in Delivery Exception Notes

Controlled Validation Summary

1. Created a delivery exception note using a partner account with a harmless proof marker embedded in markup.
2. Viewed the exception in the operations reviewer dashboard.
3. Observed browser execution of the proof marker in the dashboard context.
4. Removed the test note after validation and confirmed no external callback was used.

Root Cause

Rich-text rendering is enabled for notes, but the sanitizer allow-list does not block event-handler attributes or unsafe SVG/HTML constructs before content is displayed in dashboard widgets.

Recommended Remediation

Apply context-aware output encoding at render time and sanitize rich-text fields using a strict allow-list that excludes scriptable elements and event handlers. Add CSP with nonce-based scripts, unit tests for stored and reflected XSS cases, and a migration to neutralize existing unsafe notes.

Retest Criteria

Existing and new notes containing script-capable markup must render as inert text. Dashboard CSP violation logs should show no inline execution path and functional note formatting should remain intact.

DETAILED OBSERVATION 04 - HF-04**HF-04 - Password Reset Token Reuse After Successful Account Recovery****HIGH**

CVSS v3.1

7.5 | CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Mapped Standard

A07:2025 - Authentication Failures | WSTG-ATHN-09 | ASVS 5.0.0 V6 Authentication

Affected Component

/account/reset/confirm and Identity Recovery service

Status / Owner

Open / Identity Platform Team

Priority

P1 - invalidate token lifecycle defect

Observation and Business Impact

The same password reset token remained valid after a successful password change. The token could be replayed within the assessed window to set a second password without a new recovery email.

If a reset link is exposed through mailbox compromise, proxy logs, browser history, or helpdesk forwarding, it can remain usable after the legitimate user completes recovery. This increases account takeover persistence risk.

Proof of Concept Evidence

Evidence Capture - HF-04

HIGH

Password Reset Token Reuse After Successful Account Recovery

First successful reset confirmation

```
01 POST /account/reset/confirm HTTP/2
02 Host: partner.heliosfleet.internal
03 Content-Type: application/json
04
05 {
06   "token": "rst_8f4c7...2a9e",
07   "newPassword": "<redacted>"
08 }
09 # Response observed at 14:44:18 IST
```

Replay of same token after password change

```
01 HTTP/2 200 OK
02 content-type: application/json
03
04 {
05   "message": "Password reset completed",
06   "userId": "USR-10938",
07   "tokenStatus": "accepted",
08   "sessionRevoked": true
09 }
10 # Replay observed at 14:47:32 IST using same token
```

PoC interpretation

The reset token was accepted again after the first successful recovery. A single-use consumed flag was not enforced during password update.

Figure 5: Evidence capture for HF-04 - Password Reset Token Reuse After Successful Account Recovery

Controlled Validation Summary

1. Requested password recovery for a test account and completed reset using the emailed token.
2. Replayed the same token after successful password change within the assessment window.
3. Observed a second successful password update instead of token invalidation.
4. Verified that the replay did not require a new email or new recovery workflow.

Root Cause

Reset tokens are stored with created and expiry timestamps, but no single-use consumed flag is enforced atomically during password update.

Recommended Remediation

Make recovery tokens single-use and atomically mark tokens as consumed before completing password changes. Invalidate all outstanding reset tokens when password changes, rotate sessions, and alert users about successful recovery.

Retest Criteria

Replay of a previously used reset token must produce a generic expired or invalid-token response. Audit logs must record only one successful password reset event per token identifier.

DETAILED OBSERVATION 05 - HF-05**HF-05 - CORS Policy Reflects Untrusted Origins with Credential Support****MEDIUM**

CVSS v3.1

6.8 | CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:C/C:H/I:N/A:N

Mapped Standard

A05:2025 - Security Misconfiguration | WSTG-CLNT-07 | ASVS 5.0.0 V14 Browser Security

Affected Component

API Gateway CORS middleware for /api/v2/*

Status / Owner

Open / Cloud Platform Team

Priority

P2 - gateway configuration hardening

Observation and Business Impact

The API gateway reflects the Origin header for several authenticated API routes and sets Access-Control-Allow-Credentials: true. The assessed behavior indicates weak origin validation for partner-facing APIs.

When combined with a user browsing a malicious origin while authenticated, the browser may permit credentialed cross-origin reads from affected APIs. Practical exploitability depends on browser state and SameSite cookie controls, but the configuration expands the attack surface.

Proof of Concept Evidence

Evidence Capture - HF-05

MEDIUM

CORS Policy Reflects Untrusted Origins with Credential Support

Cross-origin browser request simulation

```
01 GET /api/v2/users/me HTTP/2
02 Host: partner.heliosfleet.internal
03 Origin: https://billing-review.trusted-client.co
04 Cookie: FOPSESS=<redacted>; SameSite=None
05 Accept: application/json
06
07 # Origin is not in approved UAT origin register
```

API gateway CORS response

```
01 HTTP/2 200 OK
02 Access-Control-Allow-Origin: https://billing-review.trusted-client.co
03 Access-Control-Allow-Credentials: true
04 Vary: Origin
05 content-type: application/json
06
07 { "userId":"USR-10938", "tenant":"ACME-LOGISTICS",
08   "email":"ops.lead@acmelogistics.co.in", "roles":["partner_ops"] }
```

PoC interpretation

The gateway reflected an unapproved origin and allowed credentialed browser reads for an authenticated API. Approved origins should be explicit and centrally managed.

Figure 6: Evidence capture for HF-05 - CORS Policy Reflects Untrusted Origins with Credential Support

Controlled Validation Summary

1. Sent authenticated API requests with an Origin header not present in the approved origin register.
2. Observed that the gateway reflected the supplied Origin value.
3. Confirmed Access-Control-Allow-Credentials: true on user profile and shipment summary APIs.
4. Validated that the behavior was gateway-level and not limited to a single endpoint.

Root Cause

CORS validation uses permissive wildcard/regex logic maintained separately from the approved domain inventory.

Recommended Remediation

Replace dynamic reflection with an explicit allow-list of production and UAT origins. Disable credentialed CORS for APIs that do not require cross-origin browser access. Validate CORS rules in automated gateway tests.

Retest Criteria

Requests from unapproved origins must not receive ACAO reflection or Access-Control-Allow-Credentials. Approved origins should continue to work with least-privilege methods and headers.

DETAILED OBSERVATION 06 - HF-06**HF-06 - Unrestricted SVG Upload Stored Under Trusted Application Origin****MEDIUM**

CVSS v3.1	6.5 CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:C/C:L/I:L/A:N
Mapped Standard	A05:2025 - Security Misconfiguration WSTG-BUSL-09 ASVS 5.0.0 V12 File Handling
Affected Component	Claims > Proof Attachment upload and /uploads/claims/* content host
Status / Owner	Open / Claims Product Team
Priority	P2 - content validation and storage isolation

Observation and Business Impact

The claims attachment workflow permits SVG files and stores them under the authenticated application origin. SVG is script-capable in browser contexts and can be abused when opened by internal users reviewing claims.

A malicious partner could upload active content that executes when staff open or preview the attachment. This can support phishing, action forgery within the application origin, or data exposure depending on surrounding browser protections.

Proof of Concept Evidence

Evidence Capture - HF-06

MEDIUM

Unrestricted SVG Upload Stored Under Trusted Application Origin

Claims attachment upload

```
01 POST /api/v2/claims/CLM-2291/attachments HTTP/2
02 Host: partner.heliosfleet.internal
03 Authorization: Bearer eyJ...partner_ops
04 Content-Type: multipart/form-data; boundary=----audit
05
06 -----audit
07 Content-Disposition: form-data; name="file"; filename="pod.svg"
08 Content-Type: image/svg+xml
09
10 <svg>...harmless proof marker...</svg>
```

Storage service response

```
01 HTTP/2 201 Created
02 content-type: application/json
03
04 {
05   "attachmentId": "ATT-77104",
06   "contentType": "image/svg+xml",
07   "previewUrl": "/uploads/claims/ATT-77104/pod.svg",
08   "disposition": "inline"
09 }
10 # File served under authenticated app origin
```

PoC interpretation

The application accepted a script-capable SVG and served it inline from the trusted application origin. Upload handling should transform, isolate, or reject active content.

Figure 7: Evidence capture for HF-06 - Unrestricted SVG Upload Stored Under Trusted Application Origin

Controlled Validation Summary

1. Uploaded an SVG proof file through the claims attachment workflow using a partner account.
2. Observed that the API accepted the upload and returned a preview URL under the authenticated application origin.
3. Opened the preview URL and confirmed inline rendering behavior.
4. Deleted the uploaded proof attachment after validation.

Root Cause

File validation relies primarily on extension and client MIME type checks. Uploaded content is served from the same origin as authenticated application workflows without forced download headers.

Recommended Remediation

Restrict upload types to business-required formats, validate server-side magic bytes, transform images to safe formats, and serve untrusted uploads from a separate cookieless domain with Content-Disposition: attachment where preview is not required.

Retest Criteria

SVG/HTML uploads must be rejected or stored as inert downloads. Existing uploaded active files should be quarantined, and accepted images must be served with safe content type and isolation controls.

DETAILED OBSERVATION 07 - HF-07**HF-07 - No Effective Rate Limiting on MFA OTP Verification Endpoint****MEDIUM**

CVSS v3.1	5.8 CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:L/A:N
Mapped Standard	A07:2025 - Authentication Failures WSTG-ATHN-03 ASVS 5.0.0 V6 Authentication
Affected Component	/api/v2/auth/mfa/verify
Status / Owner	Open / Identity Platform Team
Priority	P2 - rate limit and lockout controls

Observation and Business Impact

The MFA verification endpoint allowed repeated invalid OTP submissions from the same account and source IP without throttling, backoff, temporary lockout, or risk response. The test was rate-limited manually to avoid service disruption. Weak OTP throttling reduces MFA assurance and increases exposure to online guessing, especially when users choose predictable OTP delivery channels or if valid session preconditions are obtained through phishing.

Proof of Concept Evidence

Evidence Capture - HF-07

MEDIUM

No Effective Rate Limiting on MFA OTP Verification Endpoint

Repeated invalid MFA submissions

```
01 POST /api/v2/auth/mfa/verify HTTP/2
02 Host: partner.heliosfleet.internal
03 X-Session-Step: mfa_pending
04 Content-Type: application/json
05
06 { "otp": "135790", "factorId": "sms-primary" }
07 # 20 invalid attempts submitted at controlled low rate
```

Observed responses

```
01 HTTP/2 401 Unauthorized
02 content-type: application/json
03 retry-after: <not present>
04 x-ratelimit-remaining: <not present>
05
06 { "error": "Invalid verification code" }
07
08 # Attempt 01 -> 401
09 # Attempt 10 -> 401
10 # Attempt 20 -> 401; no 429 or lockout observed
```

PoC interpretation

The endpoint continued accepting invalid OTP guesses without backoff, lockout, or account/session counters visible in behavior. Testing volume was intentionally limited.

Figure 8: Evidence capture for HF-07 - No Effective Rate Limiting on MFA OTP Verification Endpoint

Controlled Validation Summary

1. Initiated a test login until the MFA-pending state was reached.
2. Submitted a controlled sequence of invalid OTP values from the same account and network source.
3. Observed repeated 401 responses without Retry-After, 429 throttling, or lockout behavior.
4. Stopped the test at the agreed manual cap to avoid operational side effects.

Root Cause

Rate limiting is enforced on login initiation but not on the OTP verification route. The route does not increment a failure counter tied to account, session, and network source.

Recommended Remediation

Apply adaptive rate limiting and lockout across login and MFA verification. Count failed OTP submissions per account, session, and source. Return generic errors and alert on abnormal failure volume.

Retest Criteria

After a defined number of invalid OTP attempts, the endpoint must return 429 or a temporary lockout response. The control should reset safely only after policy-defined timeout or successful risk review.

DETAILED OBSERVATION 08 - HF-08**HF-08 - Incomplete Browser Security Headers on Authenticated Pages****LOW**

CVSS v3.1	3.1 CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N
Mapped Standard	A05:2025 - Security Misconfiguration WSTG-CONF-12 ASVS 5.0.0 V14 Browser Security
Affected Component	Partner dashboard, invoice preview, and legacy report pages
Status / Owner	Open / Web Platform Team
Priority	P3 - hardening backlog with regression tests

Observation and Business Impact

Authenticated pages do not consistently set Content-Security-Policy, X-Frame-Options or frame-ancestors, Referrer-Policy, and Permissions-Policy. Several legacy report pages were frameable during the assessment.

Missing browser security headers increases the blast radius of client-side vulnerabilities and may allow clickjacking or leakage of sensitive URLs through referrers. The finding is rated low because exploitation requires user interaction and supporting conditions.

Proof of Concept Evidence

FleetOps

- Dashboard
- Shipments
- Exceptions
- Invoices
- Users
- Reports
- Settings

HF-08 - Incomplete Browser Security Headers on Authenticated Pages

Legacy aging report loaded inside an iframe from an untrusted local test origin.

Response did not include frame-ancestors or X-Frame-Options on the tested route.

CSP missing on /reports/aging and /reports/invoice-preview legacy pages.

Referrer-Policy and Permissions-Policy were not consistently applied across authenticated routes.

Browser console / application event log

```
> [header] content-security-policy: <missing>
> [header] x-frame-options: <missing>
> [header] referrer-policy: <missing on legacy report route>
> [proof] iframe render completed: frameable=true
```

PoC interpretation

The report page was frameable during validation and several hardening headers were missing. Centralized edge headers should enforce a uniform baseline.

Figure 9: Evidence capture for HF-08 - Incomplete Browser Security Headers on Authenticated Pages

Controlled Validation Summary

1. Requested authenticated legacy report routes and captured response headers.
2. Loaded the aging report route inside an iframe from an untrusted local test origin.
3. Observed successful frame rendering and missing CSP frame-ancestors / X-Frame-Options protections.
4. Compared behavior with the modern dashboard shell, which had a stronger header baseline.

Root Cause

Security headers are configured at individual application routes rather than centrally at the reverse proxy or frontend gateway.

Recommended Remediation

Set secure defaults at the edge gateway: CSP with frame-ancestors, Referrer-Policy: strict-origin-when-cross-origin, Permissions-Policy with minimal capabilities, HSTS for production, and consistent X-Content-Type-Options.

Retest Criteria

All authenticated routes must return the approved header baseline. Legacy report pages should fail iframe embedding from untrusted origins and preserve business functionality.

APPENDIX - CLOSURE GUIDANCE

Appendix A: Evidence Integrity and Retest Notes

- Evidence screenshots are sanitized to remove reusable credentials, full tokens, personal contact information, and production secrets.
- The screenshots document application behavior observed during the assessment window and should be used by engineering teams to reproduce and fix issues in controlled environments.
- Retesting should verify both direct API calls and normal UI workflows because several issues originated from inconsistencies between frontend restrictions and backend enforcement.
- For authorization fixes, include automated negative test cases for cross-tenant object IDs, unauthorized role transitions, and direct API invocation without relying on UI visibility.
- For client-side fixes, validate with both Chrome and Firefox and review CSP/reporting telemetry for blocked unsafe behavior.

Appendix B: Severity Rating Model

Severity	General Interpretation	Typical Action
Critical	Likely or proven compromise of highly sensitive data, privilege boundary, or core business workflow	Emergency fix or compensating control before release
High	Material confidentiality, integrity, or authentication impact with realistic exploitation conditions	Prioritize in current sprint and retest
Medium	Security weakness requiring specific preconditions or chained exploitation	Fix in planned remediation window
Low	Hardening issue or limited-impact defect that improves defense-in-depth	Address through baseline hardening backlog

End of Report